

Identify the Gap

Hydroficient IoT Cyber Defense Externship – Project 5, Step 1

Estimated time to complete: 15 minutes

Instructions: Complete all three parts below. Fill in the blanks, check the boxes that apply, and write your analysis in the spaces provided. Submit this document to the shared Google Doc when finished.

Part 1: Review Your Project 4 Configuration

Open your `mosquitto_tls.conf` from Project 4 and answer these questions.

1. What port is the TLS listener using?

Port: _____8883_____

2. What files are specified for the broker's identity?

CA file: _____ca.pem_____

Certificate file: _____server.pem_____

Key file: _____server-key.pem_____

3. Is there a `require_certificate` line?

- ☐ Yes, it's set to true
- ☐ **Yes, it's set to false**
- ☐ No, this line doesn't exist

4. Based on your configuration, what type of TLS is this?

- ☐ **One-Way TLS (server proves identity only)**
- ☐ Mutual TLS (both sides prove identity)

Part 2: The Rogue Device Scenario

Scenario: An attacker gains physical access to The Grand Marina's network closet. They connect a Raspberry Pi to the network and try to connect to your MQTT broker.

Answer these questions about your current (Project 4) configuration:

1. Can the attacker's device connect to the broker?

- ☐ Yes
- ☐ No

Explain why:

Because the Mosquitto configuration doesn't require a client certificate to prove that it is allowed to connect to the broker

2. What would the attacker need to successfully connect?

- ☐ Just network access
- ☐ **Network access + the CA certificate**
- ☐ Network access + CA certificate + device certificate + private key

3. Once connected, what could the attacker do? (Check all that apply)

- ☐ Subscribe to all topics and read sensor data
- ☐ **Publish fake sensor readings**
- ☐ Send commands to HYDROLOGIC devices
- ☐ **Pretend to be any device ID they want**
- ☐ **Take over legitimate device connections**

Part 3: Three Scenarios Where One-Way TLS Fails

List three realistic scenarios where your current one-way TLS configuration would fail to prevent an attack.

Hint: Consider insider threats, compromised devices, rogue hardware, man-in-the-middle attacks, or credential theft.

Scenario 1

Scenario name: A rogue device joins the network

Describe the attack:

A contractor visits Grand Marina and plugs their laptop into the hotel network. With just `ca.pem` they can connect to the broker and start publishing **fake sensor readings** — fake pressure values, fake flow rates — and the broker accepts it without question because One-Way TLS never asks the client "who are you?"

Scenario 2

Scenario name: A stolen or leaked `ca.pem`

Describe the attack:

`ca.pem` is the **public** certificate — it's not secret by design. Anyone can have it. So if a former employee, a hacker, or even someone who found it in an unsecured folder tries to connect from anywhere on the network, the broker lets them straight in.

Scenario 3

Scenario name: A compromised device gets replaced with a fake one

Describe the attack:

Imagine GM-HYDROLOGIC-02 (Pool/Spa sensor) gets physically stolen. Someone swaps it with their own device at the same location. With One-Way TLS, the broker has no way to know the difference — it just sees an encrypted connection, not **which** device is connecting.